Security

Chapter 6

Introduction

- system stores authorization rules and enforces them for database access.
- Database security can be
- Unauthorized access or manipulation of database creates problems for organization.
- Security refers to protection of data against unauthorized disclosure, alteration or destruction.
- main objectives of designing secured database system are integrity, availability and secrecy.
- Database security is about controlling access to information i.e. some information be available freely and other information be available to certain authorized people or groups.

Protection from malicious attempts to steal or modify data.

★ Database system level

✔ Authentication and authorization mechanisms to allow specific users access only to required data

✔ We concentrate on authorization in the rest of this chapter

★ Operating system level

✔ Operating system super-users can do anything they want to the database! Good operating system level security is required.

★ Network level: must use encryption to prevent

✔ Eavesdropping (unauthorized reading of messages)

✔ Masquerading (pretending to be an authorized user or sending messages supposedly from authorized users)

★ Physical level

✔ Physical access to computers allows destruction of data by intruders; traditional lock-and-key security is needed

✔ Computers must also be protected from floods, fire, etc.

★ Human level

✔ Users must be screened to ensure that an authorized users do not give access to intruders

✔ Users should be trained on password selection and secrecy

Why is database security important?

- Safeguarding the data your company collects and manages is of utmost importance. Database security can guard against a compromise of your database, which can lead to financial loss, reputation damage, consumer confidence disintegration, brand erosion, and non-compliance of government and industry regulation.
- Database security safeguards defend against a myriad of security threats and can help protect your enterprise from:
- Deployment failure
- Excessive privileges
- Privilege abuse
- Platform vulnerabilities
- Unmanaged sensitive data
- Backup data exposure
- Weak authentication
- Database injection attacks

Threats to Database

- **Availability loss** − Availability loss refers to non-availability of database objects by legitimate users.
- **Integrity loss** − Integrity loss occurs when unacceptable operations are performed upon the database either accidentally or maliciously. This may happen while creating, inserting, updating or deleting data. It results in corrupted data leading to incorrect decisions.
- **Confidentiality loss** − Confidentiality loss occurs due to unauthorized or unintentional disclosure of confidential information. It may result in illegal actions, security threats and loss in public confidence.

Measure of Control

- The measures of control can be broadly divided into the following categories −
- **Access Control** − Access control includes security mechanisms in a database management system to protect against unauthorized access. A user can gain access to the database after clearing the login process through only valid user accounts. Each user account is password protected.
- **Flow Control** − Distributed systems encompass a lot of data flow from one site to another and also within a site. Flow control prevents data from being transferred in such a way that it can be accessed by unauthorized agents. A flow policy lists out the channels through which information can flow. It also defines security classes for data as well as transactions.
- **Data Encryption** − Data encryption refers to coding data when sensitive data is to be communicated over public channels. Even if an unauthorized agent gains access of the data, he cannot understand it since it is in an incomprehensible format.

Database Security and the DBA

- The database administrator (**DBA**) is the central authority for managing a database system.
  - The DBA's responsibilities include
    - granting privileges to users who need to use the system
    - classifying users and data in accordance with the policy of the organization
- The DBA is responsible for the overall security of the database system.
  - The DBA has a DBA account in the DBMS
    - Sometimes these are called a system or superuser account
    - These accounts provide powerful capabilities such as:
      - 1. Account creation
      - 2. Privilege granting
      - 3. Privilege revocation
      - 4. Security level assignment
    - Action 1 is access control, whereas 2 and 3 are discretionarym and 4 is used to control mandatory authorization

Authorization

Forms of authorization on parts of the database:

Read authorization - allows reading, but not modification of data.

Insert authorization - allows insertion of new data, but not modification of existing data.

Update authorization - allows modification, but not deletion of data.

Delete authorization - allows deletion of data

Authorization

Forms of authorization to modify the database schema:

Index authorization - allows creation and deletion of indices.

Resources authorization - allows creation of new relations.

Alteration authorization - allows addition or deletion of attributes in a relation.

Drop authorization - allows deletion of relations.

Authorization and Views

Users can be given authorization on views, without being given any authorization on the relations used in the view definition

Ability of views to hide data serves both to simplify usage of the system and to enhance security by allowing users access only to data they need for their job

A combination or relational-level security and view-level security can be used to limit a user’s access to precisely the data that user needs.

View Example

Suppose a bank clerk needs to know the names of the customers of each branch, but is not authorized to see specific loan information.

★ Approach: Deny direct access to the *loan* relation, but grant access to the view *cust-loan*, which consists only of the names of customers and the branches at which they have a loan.

★ The *cust-loan* view is defined in SQL as follows:

create view *cust-loan* **as**
 select *branchname*, *customer-name*
 from *borrower, loan*
 where *borrower.loan-number* = *loan.loan-number*

View Example

The clerk is authorized to see the result of the query:

select *
 from *cust-loan*

When the query processor translates the result into a query on the actual relations in the database, we obtain a query on *borrower* and *loan*.

Authorization must be checked on the clerk's query before query processing begins.

Authorization on Views

Creation of view does not require **resources** authorization since no real relation is being created

The creator of a view gets only those privileges that provide no additional authorization beyond that he already had.

E.g. if creator of view *cust-loan* had only **read** authorization on *borrower* and *loan*, he gets only **read** authorization on *cust-loan*

Granting of Privileges

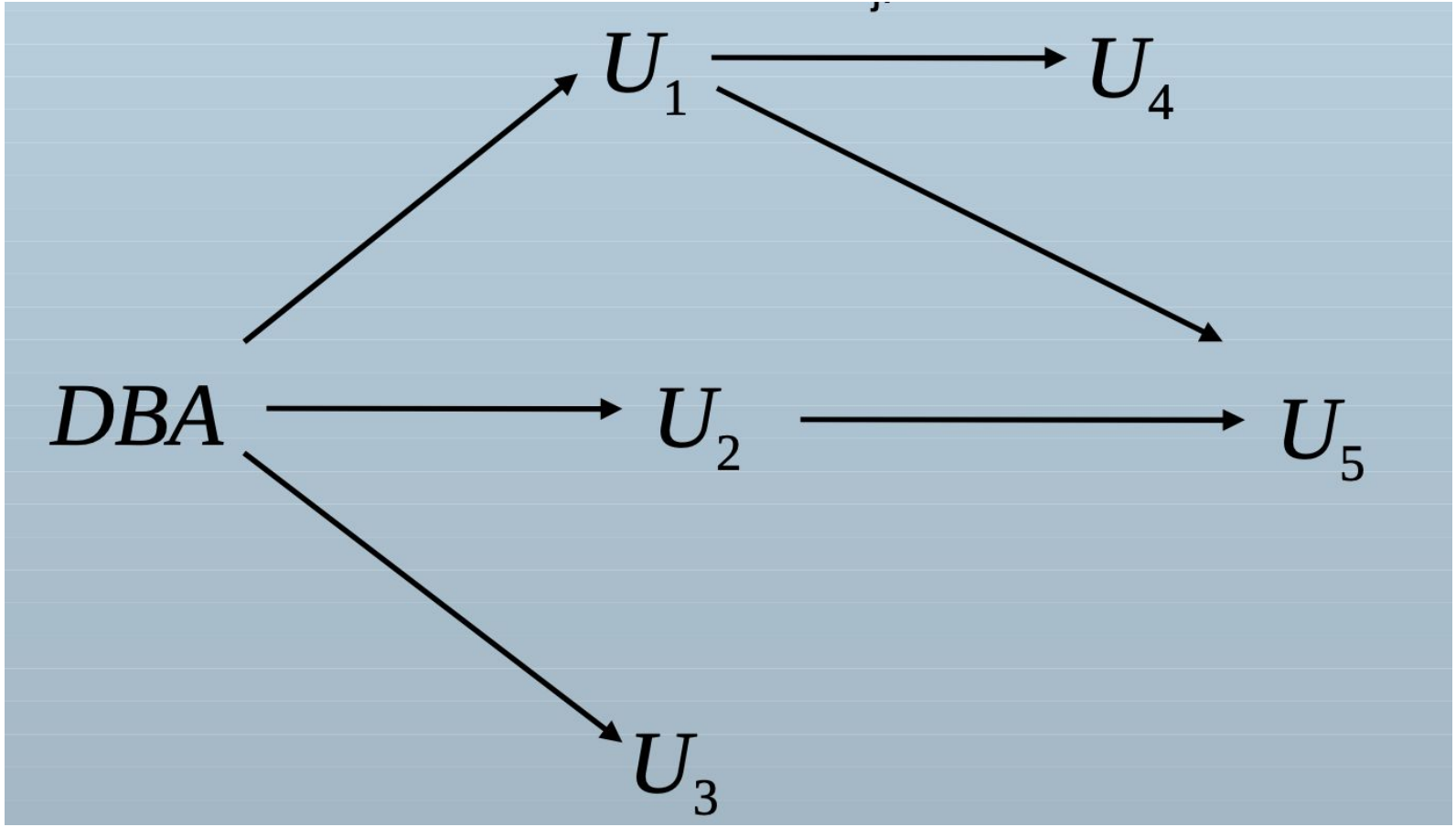
The passage of authorization from one user to another may be represented by an authorization graph.

The nodes of this graph are the users.
The root of the graph is the database administrator.

Consider graph for update authorization on loan.

- An edge $U_i \rightarrow U_j$ indicates that user U_i has granted update authorization on loan to U_j.

Granting of Privileges



Privileges in SQL

select: allows read access to relation,or the ability to query using the view

★ Example: grant users U_1, U_2, and U_3 **select** authorization on the *branch* relation:

grant select on *branch* **to** U_1, U_2, U_3

- **insert**: the ability to insert tuples
- **update**: the ability to update using the SQL update statement
- **delete**: the ability to delete tuples.
- **references**: ability to declare foreign keys when creating relations.
- **usage**: In SQL-92; authorizes a user to use a specified domain
- **all privileges**: used as a short form for all the allowable privileges

Encryption

Data may be *encrypted* when database authorization provisions do not offer sufficient protection.

Properties of good encryption technique:

- ★ Relatively simple for authorized users to encrypt and decrypt data.
- ★ Encryption scheme depends not on the secrecy of the algorithm but on the secrecy of a parameter of the algorithm called the encryption key.
- ★ Extremely difficult for an intruder to determine the encryption key.

Data Encryption Standard (DES) substitutes characters and rearranges their order on the basis of an encryption key which is provided to authorized users via a secure mechanism. Scheme is no more secure than the key transmission mechanism since the key has to be shared.

Advanced Encryption Standard (AES) is a new standard replacing DES, and is based on the Rijndael algorithm, but is also dependent on shared secret keys

Public-key encryption is based on each user having two keys:

★ *public key* – publicly published key used to encrypt data, but cannot be used to decrypt data

★ *private key* -- key known only to individual user, and used to decrypt data. Need not be transmitted to the site doing encryption.

Encryption scheme is such that it is impossible or extremely hard to decrypt data given only the public key.

The RSA public-key encryption scheme is based on the hardness of factoring a very large number (100's of digits) into its prime components.

Authentication

Password based authentication is widely used, but is susceptible to sniffing on a network

Challenge-response systems avoid transmission of passwords

- ★ DB sends a (randomly generated) challenge string to user
- ★ User encrypts string and returns result.
- ★ DB verifies identity by decrypting result
- ★ Can use public-key encryption system by DB sending a message encrypted using user's public key, and user decrypting and sending the message back

Authentication

Digital signatures are used to verify authenticity of data

★ E.g. use private key (in reverse) to encrypt data, and anyone can verify authenticity by using public key (in reverse) to decrypt data. Only holder of private key could have created the encrypted data.

★ Digital signatures also help ensure **nonrepudiation:** sender cannot later claim to have not created the data

Physical Level Security

- Protection of equipment from floods, power failure, etc.
- Protection of disks from theft, erasure, physical damage, etc.
- Protection of network and terminal cables from wiretaps non- invasive electronic eavesdropping, physical damage, etc.

Solutions:

Replicated hardware:

★ mirrored disks, dual busses, etc.

★ multiple access paths between every pair of devises

Physical security: locks,police, etc.

Software techniques to detect physical security breaches.

Human Level Security

Protection from stolen passwords, sabotage, etc.

Primarily a management problem:

- ★ Frequent change of passwords
- ★ Use of “non-guessable” passwords
- ★ Log all invalid access attempts
- ★ Data audits
- ★ Careful hiring practices

Operating System Level Security

Protection from invalid logins

File-level access protection (often not very helpful for database security)

Protection from improper use of “superuser” authority.
Protection from improper use of privileged machine intructions.

Network Level Security

Each site must ensure that it communicate with trusted sites (not intruders).

Links must be protected from theft or modification of messages

Mechanisms:

- ★ Identification protocol (password-based),
- ★ Cryptography.

Database Level Security

Assume security at network, operating system, human, and physical levels.

Database specific issues:

★ each user may have authority to read only part of the data and to write only part of the data.

★ User authority may correspond to entire files or relations, but it may also correspond only to parts of files or relations.

Local autonomy suggests site-level authorization control in a distributed database.

Global control suggests centralized control.